

EXTERNAL PENETRATION TESTING ASSESSMENT REPORT

Full Name	Rifah Tasnia
Student ID	2023100000650
Serial Number	15
Course	Applied Penetration Testing Engineer: Hands-on Experience
Course Code	CADS012
Submission Date	18/05/2026

1. Executive Summary

This report presents the findings of a simulated external penetration test conducted against PosBuzz Retail Solutions as part of the Applied Penetration Testing Engineer course (CADS012). The assessment was performed across three authorized TryHackMe environments covering active reconnaissance, web application security, and vulnerability exploitation.

The assessment identified multiple critical and high-severity vulnerabilities. Most significantly, a Windows 7 host was found fully vulnerable to the EternalBlue exploit (MS17-010), allowing complete unauthenticated remote code execution with SYSTEM-level privileges. The OWASP Juice Shop assessment revealed several web application flaws, including SQL injection and broken access control that could expose customer data and administrative functions.

OverallRiskRating:CRITICAL

Assessment Area	Key Finding	Severity	Recommendation
Reconnaissance	Open SMB/RDP ports on unpatched Windows host	High	Patch & disable SMB
Web Assessment	SQL Injection, XSS, Broken Access Control	High	Input validation, WAF
Exploitation	MS17-010 EternalBlue — full system compromise	Critical	Patch KB4012212,

Immediate remediation actions, including patch management, service hardening, and secure web application security controls, are strongly recommended to reduce overall risk exposure.

2. Reconnaissance Assessment

2.1 Methodology

Active reconnaissance was performed using Nmap, with service version detection and vulnerability scanning scripts, to identify open ports, running services, and exploitable vulnerabilities on the target host.

Command used:

```
nmap -sV --script vuln <TARGET_IP>
```

2.2 Findings

Port	State	Service	Version/Notes
135/tcp	Open	msrpc	Microsoft Windows RPC
139/tcp	Open	netbios-ssn	Microsoft Windows NetBIOS
445/tcp	Open	microsoft-ds	Windows 7-10 SMB (WORKGROUP)
3389/tcp	Open	tcpwrapped	Remote Desktop Protocol (RDP)

Open ports under 1000: 3 (ports 135, 139, 445). The vulnerability scan confirmed the host is **VULNERABLE** to MS17-010 (CVE-2017-0143), a critical Remote Code Execution flaw in SMBv1.

2.3 Remediation Recommendations

- Disable SMBv1 across all systems — it is deprecated and exploitable.
- Apply Microsoft Security Bulletin MS17-010 patch (KB4012212).
- Block port 445 at the network perimeter firewall.
- Restrict or disable RDP; enforce Network Level Authentication (NLA).
- Implement regular vulnerability scanning to detect unpatched services.

3. Web Application Assessment

3.1 Methodology

The OWASP Juice Shop was assessed for common web vulnerabilities aligned with the OWASP Top 10. Testing involved manual exploitation of authentication, input handling, and access control flaws.

3.2 Findings

Vulnerability	Location	Severity	Impact
SQL Injection	Login page — email field	Critical	Authentication bypass and unauthorized database access
Cross-Site Scripting(XSS)	Search bar / feedback fields	High	Malicious scripts may enable session hijacking and phishing attacks
Broken Access Control	Admin panel direct URL access	High	Unauthorized access to administrative function and sensitive customer data
Sensitive Data Exposure	/ftp directory unauthenticated	High	Confidential files and backups are exposed to unauthorized users.

3.3 Remediation Recommendations

- Use parameterized queries / prepared statements to prevent SQL injection.
- Enforce strict input validation and output encoding to prevent XSS.
- Implement server-side access controls — never rely on client-side URL restrictions.
- Remove or restrict the /ftp directory; sensitive files must never be publicly accessible.
- Deploy a Web Application Firewall (WAF) as a defence-in-depth measure.
- Conduct regular DAST/SAST scanning and penetration testing within the SDLC.

4. Exploitation Assessment (Blue Room)

4.1 Vulnerability Details

Vulnerability	MS17-010 (EternalBlue)
CVE	CVE-2017-0143
Affected System	Microsoft Windows 7 SP1 x64 (Host: JON-PC)
Service / Port	SMBv1 — Port 445
Risk Rating	CRITICAL — Unauthenticated Remote Code Execution
Exploit Module	exploit/windows/smb/ms17_010_eternalblue

4.2 Exploitation Steps

Step 1: Vulnerability Confirmation

Nmap scan with --script vuln confirmed the target (10.10.168.56) is vulnerable to MS17-010.

Step 2: Module Selection

Metasploit Framework used to search and select exploit/windows/smb/ms17_010_eternalblue.

Step 3: Configuration

Set RHOSTS to the target IP. Default payload: windows/x64/meterpreter/reverse_tcp.

Step 4: Exploitation

Executed the exploit. ETERNALBLUE overwrite completed successfully — Meterpreter shell obtained with SYSTEM privileges.

Step 5: Shell Upgrade

Used post/multi/manage/shell_to_meterpreter to upgrade the shell. Required option: SESSION.

Step 6: Post-Exploitation

Ran hashdump to extract credentials. Non-default user identified: Jon. Cracked password: alqfna22.

4.3 Flags Retrieved

Flag	Location	Value
Flag 1	System Root	flag{access_the_machine}
Flag 2	SAM Database (passwords)	flag{sam_database_elevated_access}
Flag 3	Administrator Documents	flag{admin_documents_can_be_valuable}

4.4 Remediation Recommendations

- Immediately apply Microsoft Security Bulletin MS17-010 patch (KB4012212).
- Disable SMBv1 on all Windows systems — it is a deprecated and dangerous protocol.
- Upgrade from Windows 7 — it reached end-of-life in January 2020 and no longer receives patches.
- Implement network segmentation to limit SMB exposure between internal hosts.
- Block port 445 at the perimeter — SMB should never be exposed externally.
- Deploy EDR solutions capable of detecting Metasploit payloads and in-memory attacks.
- Enforce strong password policies to make credential cracking infeasible.

5. Conclusion

This penetration testing assessment revealed a critical security posture across the simulated PosBuzz Retail Solutions environment. The most severe finding — the unpatched MS17-010 EternalBlue vulnerability — enabled complete, unauthenticated compromise of the system, with no user interaction required. Combined with the web application vulnerabilities identified in the Juice Shop assessment, an attacker could realistically achieve full network compromise, data exfiltration, and persistent access.

Immediate priorities should be patching legacy operating systems, disabling SMBv1, and implementing robust input validation across all web-facing applications. Long-term, a structured vulnerability management programme and regular penetration testing should be adopted to maintain an acceptable security posture.

Critical Findings	1 (MS17-010 EternalBlue)
High Findings	3 (XSS, SQLi, Broken Access Control)
Systems Compromised	1 (Full SYSTEM access)
Credentials Obtained	1 (Jon / alqfna22)
Flags Captured	3 / 3